



Cooperative Bank of Oromia (S. C)

Internal Audit Process

**Audit Report on E-birr Mobile Money and
Agent Banking Platform**

March, 2026

AUDITORS PARTICIPATED IN THE ENGAGEMENT

S. No	Name of Audit Team Members	Position	Role in the Team	Signature
1	Addisu Kamsur	Principal Auditor	IT Team Leader	
2	Salomon Zerihun	Senior Auditor	IT Member	

Reviewed by:

S. No	Name of Reviewer	Position	Role in the Review	Signature
1	Yohannes Mitike	Senior Manager, IT Audit		
2				

Approved by.....

Table of Contents

Acronyms.....	iii
Executive summary	1
Introduction.....	2
Statement of Responsibility	2
Scope	2
Objectives	3
Methodology	3
Findings Summary on E-birr Mobile Money and Agent Banking Platform Audit.....	4
Conclusion	13

Acronyms

IS→Information Systems

IT→ Information Technology

E-birr→ Electronic Birr

CBO→ Cooperative Bank of Oromia

IAP→ Internal Audit Process

CIO→ Chief Information Officer

CTSO→ Chief Technology and Strategy Officer

KPIs→ Key Performance Indicators

SLA→ Service Level Agreement

API→ Application Programming Interface

NBE→ National Bank of Ethiopia

Executive summary

An audit of the E-birr Mobile Money and Agent Banking arrangement was conducted with a focus on the Chief Information Office (CIO) control environment and its associated subprocesses, namely:

- Data Management & Reporting
- Core Banking & Enterprise Systems
- Enterprise Infrastructure
- Project Management
- IT Services & Governance
- Cybersecurity

The audit observed that all supporting infrastructure underpinning the E-birr Mobile Money and Agent Banking platform is hosted within the Bank's Data Center environment. However, despite this hosting arrangement and the platform's integration with the Bank's systems, the reviewed Information Systems Process subprocesses generally demonstrated no visibility, no control ownership, and no technical oversight over the platform and its supporting control environment. It has been indicated that, except for some API-related areas, the E-birr platform is not owned or managed by the process.

However, from an audit and risk assurance perspective, the arrangement presents a significant control gap. A critical third-party digital financial service platform that is integrated with the Bank's systems, hosted within the Bank's environment, and supports customer-impacting services should not operate without clear internal governance, technical visibility, evidence-based oversight, and formally assigned accountability.

Introduction

E-birr Mobile Money and Agent Banking is a third-party digital financial services platform that supports customer-facing financial service operations through integration with the Bank's environment, including the Core Banking System and related infrastructure components.

Given the criticality of the service, its operational dependency, and its integration into the Bank's technology and transaction ecosystem, the audit was undertaken to assess whether the Bank, through the Information Systems Process, maintains adequate controls to govern, secure, monitor, support, and oversee the platform and its associated technology, data, security, and service delivery risks.

Statement of Responsibility

In line with its audit charter, the Internal Audit Process has responsibility to provide independent and objective reasonable assurance and consulting services to the management of the Bank whether governance, risk management, system of internal control, and other operation activities are carried out effectively, efficiently and in economical manner and making recommendations for improvements.

Scope

The audit covered ~~the Bank-side~~ technical and governance control environment over E-birr Mobile Money and Agent Banking within ISP, with particular focus on the following subprocesses:

- Data Management & Reporting
- Core Banking & Enterprise Systems
- Enterprise Infrastructure
- Project Management
- IT Services & Governance
- Cybersecurity

The audit focused on the Bank's governance, visibility, oversight, monitoring, and assurance controls over the E-birr arrangement rather than the internal operational management of E-birr as a separate entity.

Objectives

The objectives of the audit were to assess whether:

- The Bank has established clear governance, accountability, and oversight over E-birr as a critical third-party digital financial service provider.
- The integration between E-birr and the Bank is governed through adequate technical, operational, and security controls.
- The Bank maintains sufficient visibility, evidence, monitoring, and assurance over the platform's security, infrastructure, data processing, and operational resilience.
- Key third-party, cybersecurity, infrastructure, data, and service continuity risks are appropriately identified, governed, and controlled.

Methodology

The audit was conducted through:

- Review of available contracts, frameworks, and governance documents
- Review of relevant technical and operational evidence
- Structured questionnaires and control inquiries issued to the reviewed process
- Interviews and discussions with relevant stakeholders
- Assessment of available evidence against expected technology governance, third-party risk, infrastructure management, cybersecurity, service management, and operational assurance practices

During fieldwork, the audit noted that many subprocesses indicated that they had limited visibility or technical ownership over E-birr-related controls and often referred the audit to E-birr side or business functions. This itself was considered as part of the control weakness where it reflected lack of defined technical accountability, assurance, and evidence-based oversight.

Findings Summary on E-birr Mobile Money and Agent Banking Platform Audit

No	Findings	Criteria, Cause and Impact	Recommendations	Auditee's Response Across 5 CIO Sub-Processes
1.	Lack of established a clear and enforceable governance and ownership model over E-Birr. The Vendor Management Standards is not yet fully operational, and its applicability to partnership arrangements such as E-Birr is unclear.	Criteria: - IS Policy: 10.6. Vendors and Sourcing - IS Security Policy - Third Party Information Security Management Standard - NBE Directive: Requirements for Information Technology (IT) Management of Banks Directive No. SBB/83/2022 Articles 4.6 and 7.2(viii) Cause: - Delayed formalization of third-party governance controls	The Bank should formally designate end-to-end ownership and accountability for Ebirr across business, technology, security, infrastructure, and operational domains, and fully operationalize as a critical service provider throughout onboarding, operation, oversight, review, and exit.	

		• Lack of clearly assigned Bank-side technical ownership • Weak operationalization of lifecycle governance over critical third-party platforms <u>Impact:</u> • Critical services may operate without clear accountability • Governance gaps may prevent effective oversight, challenge, escalation, and assurance • Increased exposure to operational, compliance, and service continuity risk Risk Rating: High		
2.	API-related controls are not managed under an integrated governance approach. There are insufficient clarity and	<u>Criteria:</u> • IS Policy: 10.6. Vendors and Sourcing • IS Security Policy	The Bank should establish and evidence a formal API governance and control framework for all APIs exposed from or integrated	

	assurance over authentication, encryption, logging, monitoring, and access to API activities, supported by incomplete technical documentation.	• Third Party Information Security Management Standard • NBE Directive: Requirements for Information Technology (IT) Management of Banks Directive No. SBB/83/2022 Articles 4.6 and 7.2(viii) <u>Cause:</u> • Over-reliance on Ebirr for API and interface control management • Lack of formal Bank-side API governance and control ownership • Insufficient integration architecture documentation and technical oversight <u>Impact:</u>	with Core Banking services, including: • authentication and authorization controls, • encryption assurance, • logging and monitoring, • rate limiting, • alerting and failure handling, • technical architecture documentation, • and independent Bank access to integration evidence and logs.	
--	---	---	--	--

		- Increased risk of unauthorized access, weak interface security, transaction failure, abuse, and undetected control weakness over Core Banking-connected services - Inability to independently verify the security, resilience, and traceability of API-based transactions Risk Rating: High		
3.	E-Birr is not fully integrated into the Bank's cybersecurity and access management framework, limiting assurance over privileged access, user roles, segregation of duties, and monitoring. Second-line security oversight is also not clearly demonstrated.	Criteria: - IS Policy: 10.6. Vendors and Sourcing - IS Security Policy - Third Party Information Security Management Standard - NBE Directive: - Requirements for Information	The Bank should formally integrate Ebirr into its cybersecurity governance and second-line oversight model, including: - IAM assurance, - privileged access governance,	

		Technology (IT) Management of Banks Directive No. SBB/83/2022 Articles 4.6 and 7.2(viii) <u>Cause:</u> • Limited integration of Ebirr into the Bank's formal cyber governance and second-line assurance processes • Weak evidence-based security challenge and monitoring arrangements over the third-party platform <u>Impact:</u> • Increased risk of unauthorized access, control circumvention, delayed detection of cyber threats, and weak response readiness • Reduced ability to identify and challenge material cyber risks	• security monitoring integration, • vulnerability and exposure review, • security evidence review, • and periodic cyber assurance reporting.	
--	--	---	--	--

		affecting customer-facing services		
		Risk Rating: High		
4.	The Bank lacks sufficient visibility and independent validation over data processing, reporting accuracy, reconciliation, and regulatory/AML controls, with reliance on externally provided information.	Criteria: - IS Policy: 10.6. Vendors and Sourcing - IS Security Policy - Third Party Information Security Management Standard - NBE Directive: - Requirements for Information Technology (IT) Management of Banks Directive No. SBB/83/2022 Articles 4.6 and 7.2(viii) Cause: - Weak formal integration of Ebirr into Bank-side data	The Bank should establish a formal Ebirr data governance and reporting assurance framework covering: - data ownership, - reconciliation, - completeness and accuracy checks, - report validation, - exception review, - suspicious transaction visibility, - and regulatory reporting accountability.	

		governance and reporting assurance structures - Lack of independently controlled reporting, reconciliation, and data ownership arrangements Impact: - Increased risk of incomplete, inaccurate, or insufficiently governed data and reporting outputs - Potential exposure to financial, operational, compliance, AML/CFT, and customer-impacting control failures Risk Rating: High		
5.	Operational responsibilities and control boundaries between the Bank and E-Birr	Criteria: IS Policy: 10.6. Vendors and Sourcing	The Bank should establish a formal infrastructure governance and assurance	

	are not clearly defined, and key infrastructure controls (e.g., patching, backup, recovery) are not independently verified by the Bank.	• IS Security Policy • Third Party Information Security Management Standard • NBE Directive: Requirements for Information Technology (IT) Management of Banks Directive No. SBB/83/2022 Articles 4.6 and 7.2(viii) <u>Cause:</u> • Unclear hosting and infrastructure accountability model • Weak operational governance over third-party-managed but Bank-hosted production assets	model for Ebirr production hosting within the Bank environment, clearly defining: • ownership, • support responsibilities, • patching, • backup and recovery, • vulnerability management, • DR accountability, • and evidence-sharing requirements.	
--	--	--	--	--

		- Limited independent infrastructure assurance by the Bank <u>Impact:</u> - Increased risk of infrastructure mismanagement, weak resilience, unverified recoverability, and unresolved operational accountability in the event of service or security incidents - Elevated exposure due to production hosting within the Bank environment without equivalent control visibility Risk Rating: High		
--	--	--	--	--

Conclusion

The audit concludes that the Bank has a material governance, control, and oversight gap over the E-Birr Mobile Money and Agent Banking platform, despite it being hosted within the Bank's environment and integrated with Core Banking services.

There are no clear technical ownership, limited visibility, and weak Bank-side oversight, with key responsibilities not formally defined or effectively managed. Product ownership exists but is The product is not supported by a structured control and accountability model.

Required Management Actions

Management should:

- Define and formalize end-to-end ownership and accountability
- Establish clear technical management and oversight responsibilities
- Ensure full visibility and control over the platform and integrations
- Strengthen contractual terms to cover security, data governance, operations, monitoring, incident management, and API controls

Unless these gaps are addressed, the Bank remains exposed to operational, security, data, and service continuity risks over a critical customer-facing platform.

Auditors Name:

1. Addisu Kamsur _____

2. Salomon Zerihun _____